## PART 2: DAST Implementation

Dynamic Application Security Testing (DAST) is a security testing method that analyzes a running application to identify vulnerabilities such as SQL injection, XSS, and misconfigurations. Unlike static testing, DAST works from an external attacker's perspective.

In this setup, we use **OWASP ZAP** (Zed Attack Proxy), a widely used open-source tool for automated security scanning of web applications.

**Prerequisites**

Before starting, ensure:

- Ubuntu/Linux system
- Internet connectivity
- Sudo/root access
- Target application URL available

**. Passive Scan**

- Runs automatically while browsing the application
- Does not attack the application
- Detects issues like:
    - Missing security headers
    - Cookie misconfigurations

**2. Active Scan**

- Performs real attacks on the application
- Sends payloads to detect vulnerabilities
- Identifies:
    - SQL Injection
    - Cross-Site Scripting (XSS)
    - Command Injection

Install Docker:

Sudo apt update

apt install docker .io

service docker status

Run ZAP:

docker run --rm -v $(pwd):/zap/wrk ghcr.io/zaproxy/zaproxy:stable zap.sh -cmd -quickurl https://clahanfashion.shop/ -quickout /zap/wrk/zap-report.html

Check report:

ls

Install Apache:

Sudo apt install apache2 -y

service apache2 start

service apache2 status

Host report:

cp ./zap-report.html /var/www/html

Access:

http://<SERVER-IP>/zap-report.html

https://caitlabsweb.sequrlab.com/guacamole/#/client/MjgzAGMAbXlzcWw

Not secure 13.201.79.189/zap-report.html

**Sites: http://clahanfashion.shop https://clahanfashion.shop**

**Generated on Tue, 21 Apr 2026 06:59:05**

**ZAP Version: 2.17.0**

**ZAP by Checkmarx**

**Summary of Alerts**

| Risk Level | Number of Alerts |
|---|---|
| High | 0 |
| Medium | 4 |
| Low | 3 |
| Informational | 3 |
| False Positives: | 0 |

**Insights**

https://caitlabsweb.sequrlab.com/guacamole/#/client/MjgzAGMAbXlzcWw

Not secure 13.201.79.189/zap-report.html

**Insights**

| Level | Reason | Site | Description | Statistic |
|---|---|---|---|---|
| Low | Warning | | ZAP warnings logged - see the zap.log file for details | 6 |
| Info | Informational | | Percentage of network failures | 1 % |
| Info | Informational | http://clahanfashion.shop | Percentage of responses with status code 2xx | 100 % |
| Info | Informational | http://clahanfashion.shop | Percentage of endpoints with content type text/html | 100 % |
| Info | Informational | http://clahanfashion.shop | Percentage of endpoints with method GET | 100 % |
| Info | Informational | http://clahanfashion.shop | Count of total endpoints | 3 |
| Info | Informational | https://clahanfashion.shop | Percentage of responses with status code 2xx | 86 % |
| Info | Informational | https://clahanfashion.shop | Percentage of responses with status code 4xx | 13 % |
| Info | Informational | https://clahanfashion.shop | Percentage of endpoints with content type application/javascript | 10 % |
| Info | Informational | https://clahanfashion.shop | Percentage of endpoints with content type image/png | 20 % |
| Info | Informational | https://clahanfashion.shop | Percentage of endpoints with content type text/css | 10 % |
| Info | Informational | https://clahanfashion.shop | Percentage of endpoints with content type text/html | 30 % |
| Info | Informational | https://clahanfashion.shop | Percentage of endpoints with content type text/javascript | 10 % |
| Info | Informational | https://clahanfashion.shop | Percentage of endpoints with content type text/plain | 20 % |
| Info | Informational | https://clahanfashion.shop | Percentage of endpoints with method GET | 100 % |
| Info | Informational | https://clahanfashion.shop | Count of total endpoints | 10 |

https://caitlabsweb.sequrlab.com/guacamole/#/client/MjgzAGMAbXlzcWw

Not secure 13.201.79.189/zap-report.html

## Summary of Sequences

For each step: result (Pass/Fail) - risk (of highest alert(s) for the step, if any).

### Alerts

| Name | Risk Level | Number of Instances |
|---|---|---|
| CSP: Failure to Define Directive with No Fallback | Medium | 1 |
| CSP: Wildcard Directive | Medium | 1 |
| CSP: script-src unsafe-inline | Medium | 1 |
| CSP: style-src unsafe-inline | Medium | 1 |
| HTTPS Content Available via HTTP | Low | 4 |
| Strict-Transport-Security Header Not Set | Low | Systemic |
| X-Content-Type-Options Header Missing | Low | 5 |
| Modern Web Application | Informational | 1 |
| Re-examine Cache-control Directives | Informational | 1 |
| User Agent Fuzzer | Informational | Systemic |

### Alert Detail

https://caitlabsweb.sequrlab.com/guacamole/#/client/MjgzAGMAbXlzcWw

Not secure 13.201.79.189/zap-report.html

### Alert Detail

| Medium | CSP: Failure to Define Directive with No Fallback |
|---|---|
| Description | The Content Security Policy fails to define one of the directives that has no fallback. Missing/excluding them is the same as allowing anything. |
| URL | https://clahanfashion.shop/ |
| Node Name | https://clahanfashion.shop/ |
| Method | GET |
| Parameter | Content-Security-Policy |
| Attack | |
| Evidence | frame-ancestors 'self'; |
| Other Info | The directive(s): form-action is/are among the directives that do not fallback to default-src. |
| Instances | 1 |
| Solution | Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header. |
| Reference | https://www.w3.org/TR/CSP/<br>https://caniuse.com/#search=content+security+policy<br>https://content-security-policy.com/<br>https://github.com/HtmlUnit/htmlunit-csp<br>https://web.dev/articles/csp#resource-options |
| CWE Id | 693 |